

SÉCURITÉ IOV • ARCHITECTURE & PROTOCOLES

Sécurité de l'Internet des *Véhicules.*

PRÉSENTÉ PAR

Ahmad Saad

ENCADRANT

Samiha Ayed

CHAMP

Cybersécurité automobile

ANNÉE

2026

Sommaire.

01 Définition & Contexte

Du véhicule connecté à l'IoV · VANET, V2X et enjeux actuels

03 Architecture matérielle

ECUs, capteurs, passerelles · Bus internes CAN, LIN, FlexRay

05 Le Bus CAN en détail

Structure de trame, arbitrage · Failles de conception

02 Taxonomie de l'IoV

Niveaux d'autonomie SAE · Communications V2V, V2I, V2P, V2N

04 Architecture de communication

Intra-véhicule, V2X, Cloud · Protocoles DSRC, C-V2X, 5G

06 Systèmes ITS & Cloud

ITS-G5, PKI, OBD-II, OTA

01

CHAPITRE UN

Définition & Contexte.

Véhicules connectés, VANET et Internet des Véhicules.

DÉFINITION

Véhicule connecté & IoV.

L'*Internet des Véhicules* étend l'IoT à l'automobile : véhicules, infrastructures, piétons et cloud échangent leurs données en temps réel.

A · ÉCHELLE UNITAIRE

Véhicule connecté

Un véhicule unique disposant de capacités de communication : infodivertissement, diagnostic à distance, eCall.

B · AD-HOC LOCAL

VANET

Vehicular Ad-hoc Network : réseau ad-hoc entre véhicules proches. Ancêtre direct de l'IoV.

C · ÉCOSYSTÈME GLOBAL

Internet des Véhicules

L'écosystème complet · véhicules, infrastructure, cloud, utilisateurs · interconnectés à l'échelle globale.

02

CHAPITRE DEUX

Taxonomie de l'IoV.

Niveaux d'autonomie et types de communication.

AUTONOMIE

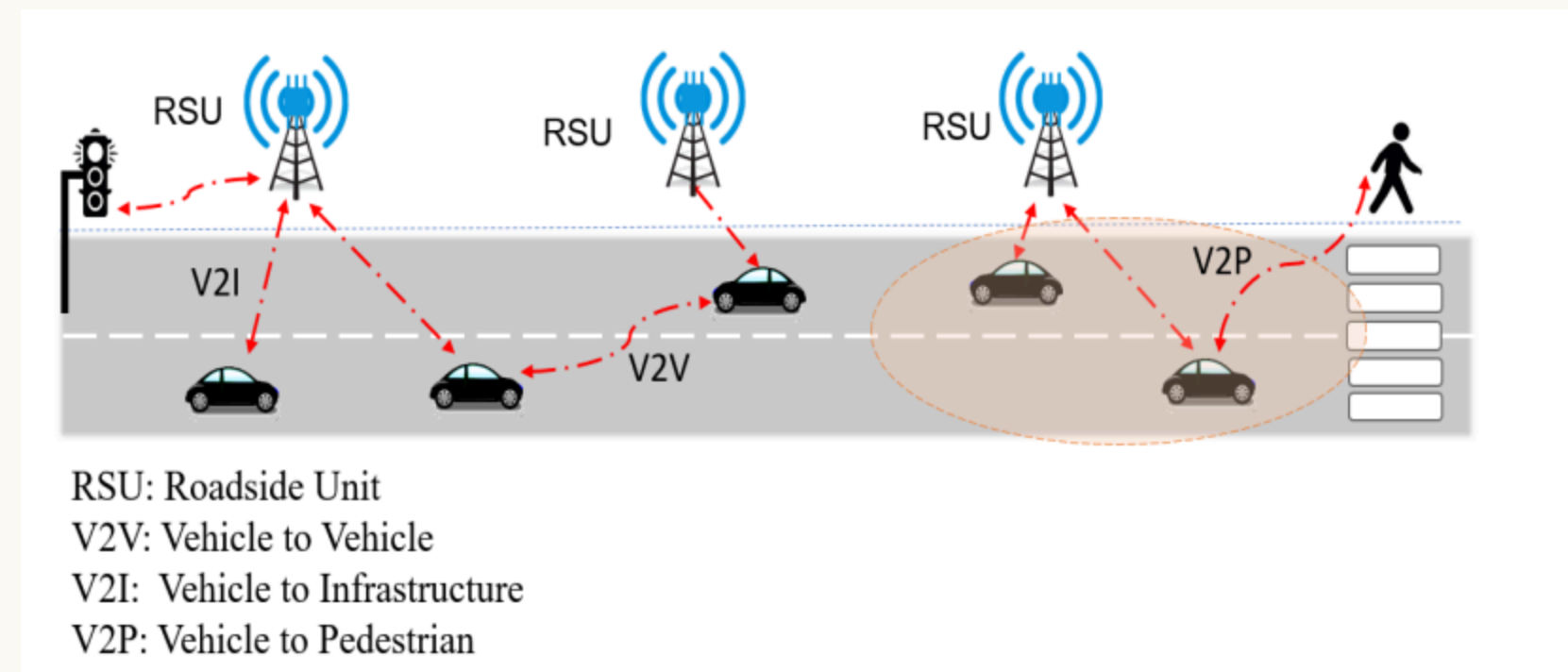
Six niveaux d'automatisation.

NIVEAU 0	NIVEAU 1	NIVEAU 2	NIVEAU 3	NIVEAU 4	NIVEAU 5
Aucune automatisation	Assistance	Automatisation partielle	Conditionnelle	Haute autonomie	Pleine autonomie
Le conducteur contrôle tout. Alertes possibles mais aucune action. Véhicule classique.	Un seul système assiste · régulateur adaptatif. Le conducteur reste pleinement responsable.	Contrôle combiné vitesse + direction. Supervision humaine permanente obligatoire.	Le véhicule gère la conduite dans certaines conditions. Reprise humaine sur alerte.	Pas d'intervention humaine dans un domaine défini. Robotaxis géo-fencés.	Conduite autonome partout, tout le temps. Aucun volant ni pédale. Non atteint commercialement.

À partir du niveau 3, le véhicule devient juridiquement et techniquement décisionnaire · la surface d'attaque change de nature.

VEHICLE-TO-EVERYTHING

Quatre familles de communication.

**V2V****Vehicle to Vehicle**

Échange direct entre véhicules proches, portée jusqu'à 1 km.

V2I**Vehicle to Infrastructure**

Dialogue avec feux, panneaux et péages via RSU.

V2P**Vehicle to Pedestrian**

Détection des piétons et cyclistes, prévention VRU.

V2N**Vehicle to Network**

Connexion cloud via 4G/5G : OTA, cartographie HD.

03

CHAPITRE TROIS

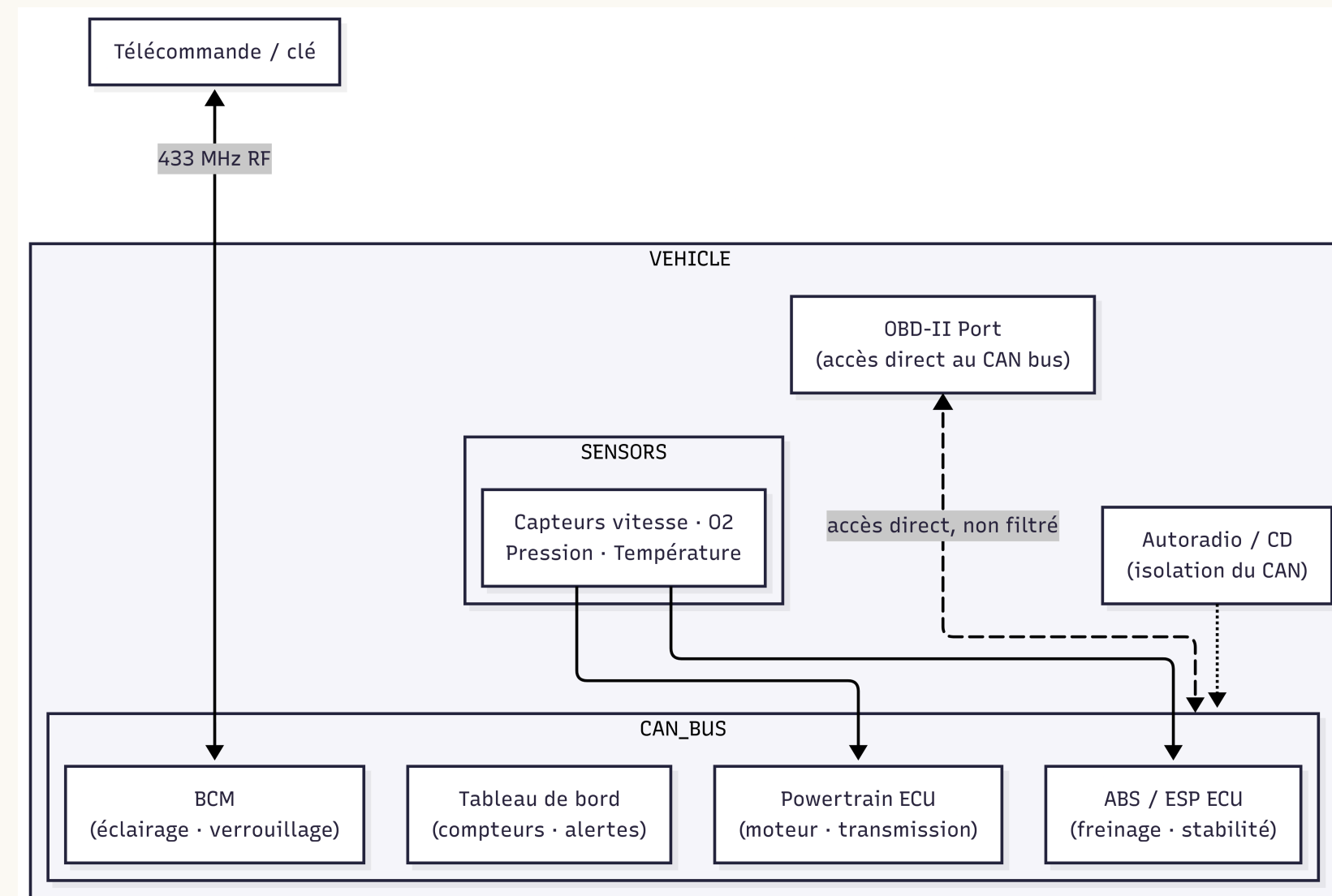
Architecture matérielle.

ECUs, capteurs et bus internes.

ARCHITECTURE HISTORIQUE

SURFACE D'ATTAQUE PHYSIQUE UNIQUEMENT

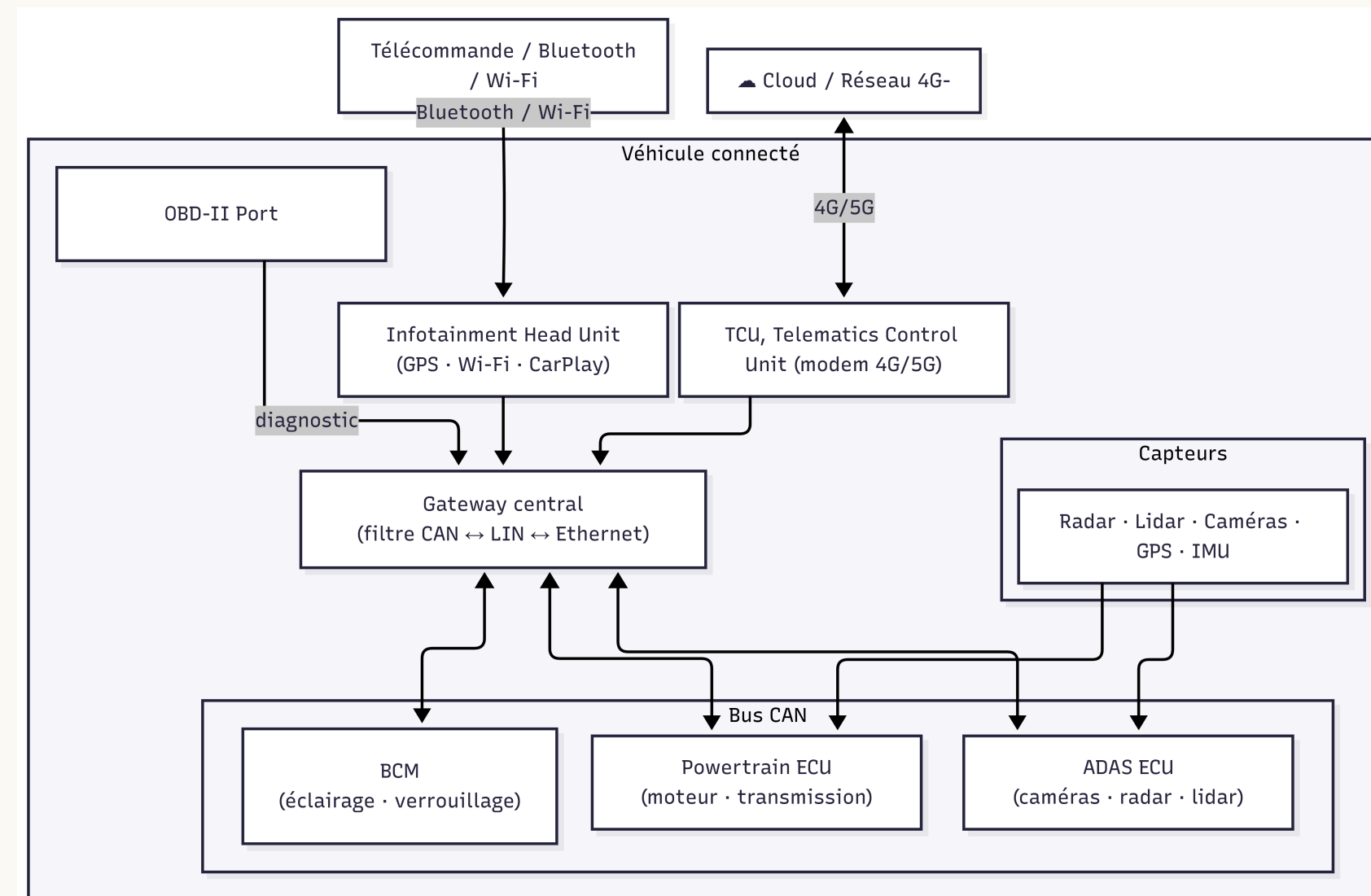
Architecture d'un véhicule non-connecté.



ARCHITECTURE MODERNE

TCU • V2X • OTA • CLOUD

Architecture d'un véhicule connecté moderne.



INVENTAIRE

Composants d'un véhicule connecté.

COMPOSANT	RÔLE
ECU	Electronic Control Unit · calculateur embarqué. 70 à 100 par véhicule moderne.
Powertrain ECU	Gestion moteur, transmission, émissions.
BCM	Body Control Module · éclairage, verrouillage, lève-vitres, essuie-glaces.
ADAS ECU	Traite caméras, radars, lidars pour l'assistance à la conduite.
Gateway central	Passerelle entre bus internes : CAN, LIN, FlexRay, Ethernet.
TCU	Telematics Control Unit · modem cellulaire 4G/5G. Porte d'entrée vers le cloud.
Head Unit	Système multimédia, GPS, Bluetooth, Wi-Fi, CarPlay / Android Auto.
OBD-II Port	Interface diagnostic standardisée · accès direct au CAN bus.
Capteurs	Radar, lidar, caméras, ultrasons, GPS, IMU.

BUS INTERNES

Une pile en transition vers Ethernet.

BUS	DÉBIT	USAGE	CARACTÉRISTIQUES
CAN	1 Mbit/s	Critique · moteur, freinage	Standard universel, arbitrage par priorité
CAN-FD	8 Mbit/s	ADAS, évolution du CAN	Payload étendu (64 octets), rétro-compatible
LIN	20 kbit/s	Confort · vitres, sièges	Bas coût, maître / esclave
FlexRay	10 Mbit/s	X-by-wire, châssis	Déterministe, tolérant aux pannes, coûteux
MOST	150 Mbit/s	Multimédia, audio	Fibre optique, remplacé par Ethernet
Auto. Ethernet	0,1 → 10 Gbit/s	ADAS, caméras, backbone	TSN, remplace les bus classiques

Architecture en évolution · les véhicules modernes passent d'une architecture distribuée (dizaines d'ECUs + multiples bus) à une architecture zonale centralisée basée sur Ethernet et quelques calculateurs haute performance (HPCs).

04

CHAPITRE QUATRE

Architecture de communication.

Intra-véhicule, V2X et Cloud.

ARCHITECTURE GLOBALE

Trois couches, trois surfaces.

COUCHE 1 · INTERNE

Intra-véhicule

- Échanges entre ECUs au sein du véhicule
- Bus CAN, LIN, FlexRay, Ethernet
- Latence ultra-faible (millisecondes)
- Temps réel pour les fonctions critiques

Cible historique des attaques.

COUCHE 2 · ENVIRONNEMENT

V2X local

- Communication véhicules, infrastructure, piétons
- Technologies DSRC / ITS-G5 et C-V2X / PC5
- Portée : quelques centaines de mètres
- Messages CAM, DENM, BSM standardisés

Sans infrastructure cellulaire requise.

COUCHE 3 · CLOUD

V2N global

- Lien cellulaire 4G / LTE ou 5G
- OTA, cartes HD, telematics
- MQTT, HTTPS, WebSocket
- Latence plus élevée (~ 50 ms)

Vecteur d'attaque à distance globale.

STANDARDS V2X

DSRC contre C-V2X.

OPTION A

DSRC / ITS-G5

- Basé sur IEEE 802.11p · Wi-Fi adapté
- Bande 5,9 GHz dédiée ITS
- Communication directe, sans infrastructure
- Mature, déployé depuis 2010
- Privilégié en Europe (ITS-G5)

OPTION B

C-V2X (PC5 + Uu)

- Spécifié par le 3GPP · LTE puis 5G NR
- Mode PC5 : direct véhicule-à-véhicule
- Mode Uu : via réseau cellulaire
- Meilleure portée, évolutif vers 5G
- Privilégié en Chine et aux USA

MESSAGES V2X STANDARDISÉS · TOUS DIFFUSÉS EN BROADCAST · LECTURE PASSIVE TRIVIALE

CAM	Cooperative Awareness · position / vitesse à 1-10 Hz	SPaT	Signal Phase and Timing · état des feux
DENM	Decentralized Environmental Notification (danger)	MAP	Topologie d'une intersection
BSM	Basic Safety Message · équivalent US du CAM	IVI	In-Vehicle Information · panneaux virtuels

05

CHAPITRE CINQ

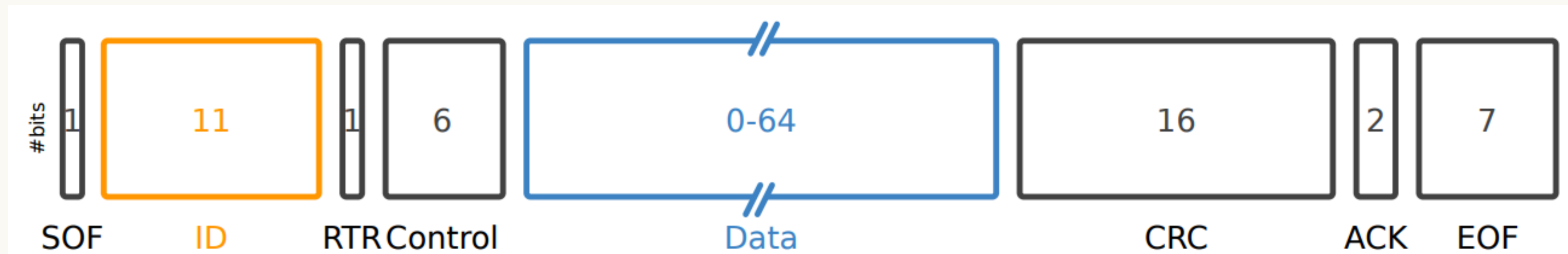
Le Bus CAN.

Le protocole de référence du véhicule.

PROTOCOLE CAN

Quarante ans de bus, zéro authentification.

STRUCTURE D'UNE TRAME CAN STANDARD



PRÉSENTATION

- Inventé par Bosch en 1986, standard ISO 11898
- Bus différentiel à 2 fils (CAN_H / CAN_L)
- Débit 125 kbit/s à 1 Mbit/s (CAN 2.0)
- Topologie multi-maître avec arbitrage
- Détection d'erreurs par CRC

PRINCIPE D'ARBITRAGE

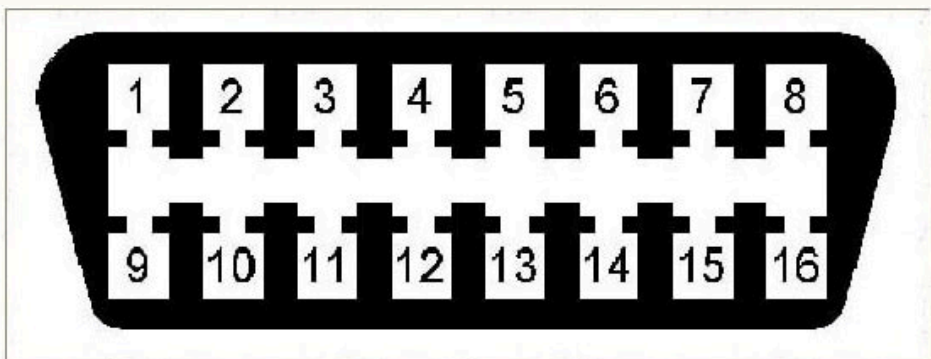
L'**identifiant le plus faible** gagne toujours l'arbitrage. En cas de collision, le message à plus haute priorité passe en premier · non destructif.

*Conséquence immédiate : un attaquant émettant en boucle avec **ID = 0x000** peut paralyser le bus entier.*

PORT DIAGNOSTIC

La porte d'entrée légale.

Un connecteur 16 broches obligatoire depuis 1996 (USA) et 2001 (UE). Il offre un accès direct au bus CAN · pour le diagnostic, et donc pour l'attaquant.



PIN	DESCRIPTION	PIN	DESCRIPTION
1	Vendor Option	9	Vendor Option
2	J1850 Bus +	10	j1850 BUS
3	Vendor Option	11	Vendor Option
4	Chassis Ground	12	Vendor Option
5	Signal Ground	13	Vendor Option
6	CAN (J-2234) High	14	CAN (J-2234) Low
7	ISO 9141-2 K-Line	15	ISO 9141-2 Low
8	Vendor Option	16	Battery Power

OBD-II Connector and Pinout

NORME

Qu'est-ce que l'OBD-II ?

- On-Board Diagnostics II · standard obligatoire
- Connecteur 16 broches sous le tableau de bord
- Accès direct au bus CAN

USAGES LÉGITIMES

Lecture, diagnostic, flash

- Lecture des codes défaut (DTC)
- Diagnostic en concession, contrôle pollution
- Reprogrammation ECUs · dongles de tracking

06

CHAPITRE SIX

Écosystème ITS & Cloud.

PKI, OTA et gestion du trafic intelligent.

PKI V2X

Signature dès la conception.

Contrairement à MAVLink ou ADS-B, la norme V2X intègre *dès la conception* un système de signature cryptographique basé sur une PKI dédiée.

PRINCIPE

Certificats à courte durée de vie

- Certificat émis par une autorité de confiance (RCA)
- Chaque message CAM / DENM signé par ECDSA
- Pseudonymes à court terme pour la vie privée
- Des milliers de pseudonymes par véhicule

ACTEURS & STANDARDS

Trois autorités, quatre standards

- RCA · Root Certificate Authority
- EA · Enrollment Authority (long terme)
- AA · Authorization Authority (pseudonymes)

- IEEE 1609.2 · USA · WAVE
- ETSI TS 103 097 · Europe · ITS
- SCMS / C-ITS · modèles de confiance

Limite · un certificat légitime volé permet d'émettre des messages signés malveillants.

OTA

Mises à jour à distance.

L'OTA met à jour le firmware des ECUs à distance via le cloud. Généralisé chez les constructeurs depuis 2012.

PRINCIPE

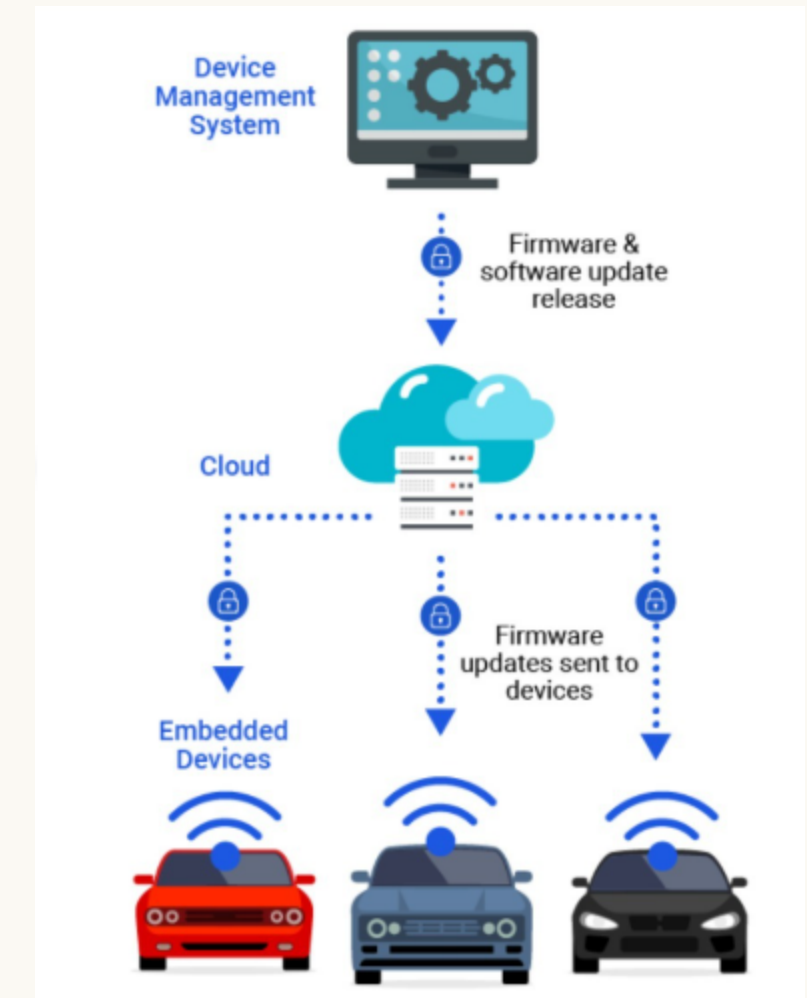
Deux niveaux de mise à jour

- SOTA · Software (infotainment)
- FOTA · Firmware (ECUs critiques)

AVANTAGES

Pourquoi c'est devenu standard

- Correctifs de sécurité rapides
- Nouvelles fonctionnalités post-vente
- Réduction des rappels coûteux et économies logistiques



PARTIE DEUX

Vulnérabilités & Attaques.

Pourquoi ces systèmes sont-ils vulnérables · et comment les attaquer ?

CHAPITRES

07 · 08 · 09 · 10 · 11 · 12 · 13

AXES

Intra-véhicule · V2X · Capteurs

CIBLE

Surface d'attaque complète

CLÔTURE

Normes, conformité &
conclusion

07

CHAPITRE SEPT

Surface d'attaque.

Cartographie des systèmes exposés.

CARTOGRAPHIE

Trois axes d'attaque.

Les cyberattaques IoV se regroupent selon la cible visée : le bus interne, le tissu V2X ou les capteurs et interfaces externes.

AXE	SYSTÈMES CIBLÉS
INTRA-VÉHICULE	Bus CAN · ECUs · port OBD-II
V2X · INTER-VÉHICULES	DSRC / ITS-G5 · C-V2X · RSU
CAPTEURS & INTERFACES	GPS · LiDAR · caméras · TPMS · Bluetooth · télématique

08

CHAPITRE HUIT

Attaques intra-véhicule.

Bus CAN, ECUs et port OBD-II.

FAILLES DE CONCEPTION

Quatre failles structurelles.

A · AUTHENTICATION

Absence d'authentification

Aucun champ d'adresse source dans la trame CAN. N'importe quel nœud peut émettre n'importe quel ID. Un ECU ne peut pas distinguer un message légitime d'un message forgé.

C · ARBITRAGE

Priorité exploitable

L'ID le plus faible gagne toujours l'arbitrage. Un attaquant émettant en boucle avec ID = 0x000 bloque tout le bus · déni de service trivial.

Cas d'école · En 2015, Miller & Valasek démontrent le contrôle à distance d'un SUV via le système télématique : coupure du moteur, freinage et direction à 110 km/h. Rappel de 1,4 million de véhicules.

B · CONFIDENTIALITÉ

Absence de chiffrement

Toutes les trames transitent en clair. Un dongle OBD-II ou un tap sur les fils CAN lit instantanément vitesse, régime moteur, angle volant, pression des freins...

D · SEGMENTATION

Pas de segmentation historique

CAN confort et CAN powertrain reliés par une passerelle peu filtrante. Compromettre la radio Bluetooth peut suffire à atteindre les freins.

ATTAQUE 01 / 05

Écoute passive (CAN Sniffing).

PRINCIPE

Un dongle OBD-II ou un adaptateur CAN (CANtact, CANable) branché sur le port diagnostic capture toutes les trames en circulation sur le bus.

Outils courants : SocketCAN + candump sous Linux, SavvyCAN, Wireshark avec dissecteur CAN.

DONNÉES EXTRAITES

- Vitesse du véhicule, régime moteur
- Angle du volant, position des pédales
- État des clignotants, des portes
- Pression des pneus (TPMS)
- Codes défaut et paramètres ECU

Reverse engineering · Les IDs ne sont pas documentés publiquement. L'attaquant les identifie par observation : actionner un clignotant, noter l'ID qui change. Des outils comme *caringcaribou* automatisent ce processus.

ATTAQUE 02 / 05

Injection de trames CAN.

PRINCIPE

L'attaquant émet des trames forgées sur le bus depuis un nœud connecté · dongle OBD-II, ECU compromis ou tap physique.

Sans adresse source ni authentification, l'ECU cible accepte toute trame dont il écoute l'ID.

Condition : accès au bus · physique ou via une interface externe compromise (Bluetooth, telematics, infotainment).

IMPACT SELON L'ECU CIBLÉ

- Dynamique : freins, direction, accélérateur, transmission
- Affichage : tableau de bord, voyants, compteur
- Confort & sécurité : portes, airbags, éclairage
- Diagnostic : effacement de codes, reprogrammation ECU

Démonstration historique · Miller & Valasek (2015) ont injecté des trames CAN sur un SUV pour couper le moteur, désactiver les freins et tourner le volant à distance · depuis Internet via la TCU.

TRAMES & IMPACTS

Quelles trames, quels effets.

TRAME INJECTÉE	IMPACT
ID compteur vitesse (falsifié)	Afficher une fausse vitesse au tableau de bord
ID direction assistée	Tourner le volant indépendamment du conducteur
ID frein ABS	Déclencher ou désactiver les freins
ID accélérateur électronique	Accélérer ou couper les gaz à volonté
ID transmission	Forcer un changement de rapport, passer au neutre
ID verrouillage central (BCM)	Verrouiller / déverrouiller les portes à distance
ID airbag	Déclencher un airbag hors collision
ID climatisation	Actionner la ventilation, le chauffage des sièges
ID klaxon / essuie-glaces	Actionnement inopiné
UDS · Unified Diagnostic Services	Effacer les codes défaut, entrer en mode programmation
Flash firmware ECU	Reprogrammer un ECU avec un firmware malveillant

ATTAQUE 03 / 05

Rejeu CAN.

PRINCIPE

L'attaquant enregistre une séquence CAN légitime · par exemple le déverrouillage par télécommande · puis la rejoue plus tard sans aucune modification.

Sans horodatage signé ni nonce, le CAN ne distingue pas un message frais d'un rejeu.

SCÉNARIOS CONCRETS

- Déverrouillage : capturer puis rejouer la séquence pour ouvrir le véhicule
- Démarrage : rejouer l'autorisation de l'immobiliseur
- Effacement DTC : rejouer la commande pour masquer les traces d'intrusion

Relay Attack sans contact · Variante sans fil : deux attaquants relaient le signal radio entre le véhicule et la clé restée dans la maison. Technique massivement utilisée contre les véhicules à ouverture keyless.

ATTAQUE 04 / 05

Déni de service (Bus Flooding).

PRINCIPE

L'attaquant émet en continu des trames CAN avec **ID = 0x000** · priorité maximale absolue.

L'ID le plus faible gagne toujours l'arbitrage : les autres ECUs sont repoussés en retransmission, le bus est paralysé.

CONSÉQUENCES

- Le tableau de bord fige ou affiche des erreurs
- ABS, ESP, direction assistée cessent de dialoguer
- Passage en mode limp home ou arrêt moteur
- Impossible à distinguer d'une défaillance matérielle
- Un seul nœud malveillant suffit

Bus-Off Attack · Variante subtile : exploiter la machine d'état d'erreur CAN pour forcer un ECU légitime à passer en mode bus-off. Décrite par Cho & Shin (USENIX 2016), elle fait taire sélectivement un ECU sans flooder tout le bus.

ATTAQUE 05 / 05

Reflash malveillant d'ECU.

PRINCIPE

Via le protocole **UDS** (Unified Diagnostic Services · ISO 14229), un attaquant avec accès au CAN peut entrer en mode programmation et réécrire le firmware d'un ECU.

Si la protection **Security Access** (seed & key) est faible ou que l'algorithme a fuité, la procédure complète est possible.

CONSÉQUENCES

- Backdoor persistante survivant aux redémarrages
- Modification des cartographies moteur (chip tuning malveillant)
- Désactivation silencieuse de fonctions de sécurité
- Bricking volontaire (refus de démarrage)
- Quasi-impossible à détecter sans comparer au firmware d'origine

Seed & Key · De nombreux algorithmes Seed & Key constructeur ont été reverse-engineerés et publiés. Des outils commerciaux de tuning utilisent ces mêmes failles · preuve que la protection est insuffisante.

09

CHAPITRE NEUF

Attaques V2X.

Coordination inter-véhicules et infrastructure.

MODÈLE DE MENACE

Broadcast signé, confiance implicite.

A

Modèle broadcast

Les messages CAM, DENM, BSM sont diffusés en clair (signés mais non chiffrés) plusieurs fois par seconde. Tout récepteur à portée peut les capter.

Tracking de masse · la corrélation de trajectoires permet le suivi à long terme malgré les certificats pseudonymes.

B

Confiance implicite

Un véhicule recevant une alerte DENM signée par un certificat valide y fait confiance · aucune validation sémantique que l'alerte correspond à la réalité physique.

Un certificat volé permet de signer n'importe quel message légitime jusqu'à révocation.

ATTAQUE 01 / 05

Attaque Sybil.

PRINCIPE

Un attaquant unique se fait passer pour plusieurs véhicules fantômes en utilisant plusieurs certificats pseudonymes · obtenus légitimement ou volés.

Il émet simultanément de multiples flux CAM/BSM donnant l'illusion d'un trafic dense inexistant.

CONSÉQUENCES

- Fausse congestion → détournement du trafic réel
- Ondes vertes fictives aux feux intelligents
- Surcharge des RSU et systèmes de déconfliction
- Validation mutuelle de fausses alertes (plusieurs fantômes témoignent)
- Manipulation des véhicules autonomes voisins

ATTAQUE 02 / 05

Injection de fausse alerte DENM.

PRINCIPE

L'attaquant émet un message DENM signé annonçant un événement fictif : accident, véhicule à l'arrêt, chaussée glissante, obstacle sur la voie.

Les véhicules récepteurs déclenchent automatiquement une manœuvre d'évitement · freinage d'urgence ou changement de voie.

SCÉNARIOS

- Freinage d'urgence en cascade sur autoroute → carambolage
- Détournement d'un convoi vers une route piégée
- Paralysie d'un carrefour stratégique
- Déclenchement d'AEB sur un véhicule poursuivant · collision arrière
- Évacuation forcée d'une zone

Risque · Un attaquant immobile au bord d'une autoroute, avec un simple SDR et un certificat V2X valide, peut provoquer des accidents en chaîne à plusieurs kilomètres. Impact disproportionné.

ATTAQUE 03 / 05

Rejeu de messages V2X.

PRINCIPE

L'attaquant enregistre des messages V2X légitimes (signés) émis dans un contexte particulier, puis les rejoue dans un autre contexte temporel ou géographique.

Si la fenêtre de validité des timestamps est trop large, ou si le contrôle géographique est absent, le message est accepté.

EXEMPLES

- Rejouer une alerte freinage d'urgence capturée la semaine précédente
- Rejouer un SPaT (état des feux) pour tromper un véhicule autonome
- Rejouer les trames d'un véhicule prioritaire pour forcer le vert
- Wormhole : capturer ici, rejouer ailleurs via un tunnel rapide

ATTAQUE 04 / 05

Brouillage & Éclipse.

JAMMING ITS-G5 / PC5

Un émetteur haute puissance sur la bande 5,9 GHz sature le canal V2X. Les véhicules à portée ne reçoivent plus aucun message cohérent.

Effet : perte immédiate de la conscience coopérative. Les véhicules retombent sur leurs seuls capteurs locaux.

ATTAQUE PAR ÉCLIPSE

L'attaquant sature le récepteur d'une cible unique avec du trafic légitime forgé, évinçant les messages des véhicules réellement présents.

La cible a l'impression de conduire dans un environnement normal, mais sa vision V2X est entièrement contrôlée par l'attaquant.

Asymétrie · Contrairement aux bus internes, la portée du brouillage peut couvrir une autoroute entière pour un coût modeste. Les véhicules autonomes de niveau 3+ qui dépendent du V2X sont particulièrement exposés.

ATTAQUE 05 / 05

Compromission d'une RSU.

PRINCIPE

Les RSU (Road-Side Units) sont des équipements déployés au bord des routes : feux intelligents, panneaux à messages variables, bornes de péage.

Beaucoup sont installés dans des armoires non sécurisées, avec un firmware rarement mis à jour et des ports de maintenance accessibles.

Une RSU compromise est une autorité de confiance pour tous les véhicules à portée.

CONSÉQUENCES

- Fausses informations SPaT (feu vert fictif) → collisions aux intersections
- Injection de DENM signés par l'infrastructure · crédibilité maximale
- Collecte massive des données CAM → surveillance de masse
- Point de pivot vers le réseau ITS central

Impact systémique · Une seule RSU compromise à une intersection majeure peut affecter des milliers de véhicules par jour. Vecteur d'attaque privilégié contre les systèmes ITS à l'échelle urbaine.

10

CHAPITRE DIX

Attaques sur capteurs & interfaces.

GPS, LiDAR, caméras, TPMS et telematics.

CAPTEURS & INTERFACES

Capteurs trompables, interfaces ouvertes.

CAPTEURS PHYSIQUES

CAPTEUR	FAILLE
GPS L1	Signal faible, non authentifié
LiDAR	Impulsions lumineuses forgeables
Caméras	Exemples adversariaux
Radar	Réflecteurs passifs ou actifs
TPMS	433 MHz, rarement chiffré
Ultrasons	Brouillage aisé (40 kHz)

Risque · les capteurs sont la seule source de vérité pour un véhicule autonome. Les tromper, c'est contrôler ses décisions.

INTERFACES EXTERNES

INTERFACE	EXPOSITION
TCU 4G / 5G	Accessible depuis Internet
Bluetooth	Portée 10 m, pile souvent buggée
Wi-Fi	Hotspots embarqués par défaut
USB infotainment	Auto-mount, parsing de médias
NFC (clé)	Portée courte mais relayable
Ports diagnostic	Accès au CAN interne

La TCU cellulaire est le vecteur le plus critique : joignable depuis Internet, souvent reliée directement au gateway CAN.

ATTAQUE 01 / 05

Leurrage GPS (Spoofing).

PRINCIPE

Des signaux GPS forgés sont diffusés avec une puissance légèrement supérieure aux vrais satellites. Le récepteur du véhicule croit se trouver à un emplacement contrôlé par l'attaquant.

Matériel : USRP / HackRF + `gps-sdr-sim` (open source).

CONSÉQUENCES

- Navigation GPS guidant le véhicule sur une route choisie
- Tromper l'Autopilot → sortie d'autoroute forcée
- Faux horodatage → perturbation des systèmes V2X
- Manipulation des fonctions GPS-dépendantes (géofencing, péage urbain)
- Sabotage de flottes logistiques

ATTAQUE 02 / 05

Attaques sur LiDAR.

PRINCIPE

Le LiDAR émet des impulsions laser et mesure le temps de retour. Un attaquant disposant d'un laser synchronisé peut :

- **Relay** · retarder les échos → objets apparaissent plus loin
- **Injection** · créer de faux obstacles inexistants
- **Aveuglement** · saturer le capteur avec une lumière intense

IMPACT

- Faux obstacle → freinage d'urgence injustifié
- Obstacle masqué → collision avec un objet réel
- Saturation → le LiDAR devient aveugle
- Tous les robotaxis de niveau 4+ sont concernés

ATTAQUE 03 / 05

Attaques adversariales (caméras).

PRINCIPE

Les systèmes ADAS reposent sur des réseaux de neurones pour classifier les panneaux, voies et obstacles.

Un motif adversarial imprimé sur un panneau ou projeté sur la chaussée peut tromper le modèle sans être perceptible par un humain.

EXEMPLES DÉMONTRÉS

- Autocollants sur un STOP → interprété comme limite 45 mph
- Projections laser au sol → fausses lignes de voie
- Motif sur T-shirt → piéton invisible au détecteur
- McAfee 2020 : accélération forcée de 50 à 85 mph en modifiant un « 3 » en « 8 »

Risque · Ces attaques sont physiquement imprimables · aucune compromission informatique nécessaire. Un autocollant suffit.

ATTAQUE 04 / 05

Attaque sur capteurs TPMS.

PRINCIPE

Le TPMS (Tire Pressure Monitoring System) est obligatoire aux USA et en UE. Chaque capteur émet en 433 MHz un identifiant unique et la pression, *rarement chiffré*.

Lecture passive · tracking unique par les IDs TPMS. Émission active · fausses alertes de pression.

CONSÉQUENCES

- Suivi d'un véhicule sur des kilomètres via ses capteurs TPMS
- Déclenchement d'alertes de crevaison fictives au tableau de bord
- Possible arrêt du conducteur → attaque ciblée (vol, enlèvement)

ATTAQUE 05 / 05

Exploitation à distance de la TCU.

PRINCIPE

La TCU (Telematics Control Unit) embarque un modem 4G/5G et fait office de passerelle vers Internet. Elle expose souvent des services (SSH, HTTP de diagnostic, MQTT) sur des IP publiques ou via APN opérateur mal segmenté.

Un attaquant distant exploite une vulnérabilité logicielle pour obtenir une exécution de code sur la TCU.

CHAÎNE D'EXPLOITATION JEEP 2015

- Port 6667 (D-Bus) exposé sur le réseau opérateur
- RCE sur la head unit télématique
- Flash d'un firmware modifié sur le microcontrôleur V850
- Envoi de trames CAN arbitraires vers le bus critique
- Contrôle des freins, moteur, direction à distance

Le vecteur le plus dangereux · *Un exploit TCU exploitable à distance = compromission potentielle de toute la flotte d'un modèle. Aucune proximité physique requise.*

11

CHAPITRE ONZE

Synthèse & Contre-mesures.

Cartographie des attaques et premières défenses.

SYNTHÈSE

Cartographie des attaques.

AXE	SYSTÈME	PROTOCOLE	ATTAQUES
INTRA-VÉHICULE	Bus interne	CAN / CAN-FD	Écoute · Injection · Rejeu · Bus Flooding · Bus-Off
INTRA-VÉHICULE	Diagnostic	UDS / OBD-II	Reflash malveillant · Seed & Key bypass
V2X	Coop. inter-véhicules	DSRC · C-V2X	Sybil · Fausses alertes DENM · Rejeu · Wormhole
V2X	Infrastructure	ITS-G5 · RSU	Compromission RSU · Jamming · Éclipse
CAPTEURS	Navigation	GPS L1	Leurrage (Spoofing)
CAPTEURS	Perception	LiDAR · Caméra · Radar	Injection · Aveuglement · Adversarial
CAPTEURS	Télémétrie pneu	TPMS 433 MHz	Tracking · Fausses alertes
INTERFACES	Telematics	TCU 4G / 5G	RCE distant · Pivot vers CAN

DÉFENSE EN PROFONDEUR

Trois lignes de défense.

PRÉVENTION

Empêcher en amont

- Gateway filtrant entre CAN critique et confort
- Architecture zonale Ethernet + authentification
- SecOC (ou TESLA / vatiCAN / LeiA) · MAC + compteur de fraîcheur sur trames CAN
- HSM embarqué (Hardware Security Module)
- Signature ECDSA V2X (IEEE 1609.2 / ETSI)
- Secure Boot + chaîne de confiance firmware
- Désactivation des ports diagnostic à distance

DÉTECTION

Repérer en vol

- IDS CAN · anomalies fréquence et séquence d'IDs
- Fingerprinting physique des ECUs
- Corrélation GPS / IMU / odométrie → détection GPS spoof
- Surveillance du volume V2X par certificat (Sybil)
- Monitoring RF 5,9 GHz → détection jamming
- SOC véhicule centralisé

ATTÉNUATION

Limiter l'impact

- Fusion multi-capteurs : caméra + radar + LiDAR + carte HD
- Mode dégradé sûr (limp home)
- Révocation rapide des certificats V2X
- OTA régulières avec signature
- Isolation du domaine safety-critical
- Conformité ISO/SAE 21434, UN R155 / R156
- Programmes Bug Bounty constructeurs

12

CHAPITRE DOUZE

Attaques déjà corrigées.

Maturité de l'industrie face aux menaces historiques.

POST-2018

Attaques intra-véhicule corrigées.

L'industrie a intégré des contre-mesures après les démonstrations publiques. AUTOSAR SecOC s'impose comme standard chez la majorité des constructeurs européens depuis 2019. → [comparatif page suivante](#)

ATTAQUE	SOLUTION DÉPLOYÉE	STATUT
Écoute CAN passive	Segmentation par gateway, isolation du CAN critique	ATTÉNUÉ
Injection de trames CAN	SecOC (MAC sur trames), filtrage par gateway central	MITIGÉ
Rejeu CAN	Compteurs anti-rejeu (freshness counters) dans SecOC	MITIGÉ
Bus Flooding (DoS)	Détection IDS embarqué + isolation par domaine zonal	DÉTECTÉ
Bus-Off Attack	Surveillance des compteurs d'erreur CAN, alertes IDS	DÉTECTÉ
Reflash malveillant ECU	Secure Boot, signature firmware obligatoire, HSM embarqué	CORRIGÉ
Seed & Key bypass (UDS)	Algorithmes cryptographiques modernes (AES / HMAC)	CORRIGÉ
Dongle OBD-II Bluetooth	Désactivation OBD hors mode atelier (vitesse > 0)	MITIGÉ

AUTHENTIFICATION DU BUS CAN

SecOC face à ses alternatives.

Chiffrer le CAN n'est pas réaliste (diffusion, temps réel). La parade industrielle est l'authentification par MAC (*SecOC*), mais ce n'est pas le seul schéma.

SCHÉMA	PRINCIPE	COMPROMIS
AUTOSAR <i>SecOC</i>	MAC tronqué (AES-128-CMAC) + Freshness Value · « vérifier ou rejeter »	Standard, adopté OEM, compatible HSM · surcoût payload → CAN-FD souvent requis
TESLA	Diffusion authentifiée par divulgation différée de clés (chaîne de hachage)	Très peu de surcoût en diffusion · latence de vérification + synchro temporelle requise
vatiCAN / LeiA	MAC + nonce / époque dans une trame d'authentification séparée	Léger, proche du CAN classique · double le trafic
CANAuth	HMAC porté hors-bande via CAN+	N'entame pas le payload · exige des transceivers spécifiques
CANcrypt	Authentification ET chiffrement, clés dynamiques par paire	Ajoute la confidentialité · plus lourd, moins temps-réel
MACsec (802.1AE) / TLS-DTLS	Intégrité / chiffrement sur Automotive Ethernet	Pour l'architecture zonale Ethernet, pas le CAN classique

Mise en œuvre du lab · *SecOC AUTOSAR · AES-128-CMAC, compteur de fraîcheur 32 bits, MAC tronqué 8 octets sur trame CAN-FD, « verify-or-drop ». La même primitive durcit aussi le SecurityAccess UDS.*

SECURITY - BY - DESIGN

Attaques V2X corrigées par conception.

Contrairement aux protocoles aviation (ADS-B, TCAS), le V2X a été conçu avec la sécurité dès l'origine. Plusieurs attaques sont structurellement empêchées · mais un certificat valide volé ou une RSU compromise restent des vecteurs ouverts.

ATTAQUE	SOLUTION DÉPLOYÉE	STATUT
Injection de DENM forgé	Signature ECDSA obligatoire (IEEE 1609.2 / ETSI 103 097)	CORRIGÉ
Usurpation d'identité	Certificats émis par PKI dédiée (SCMS / C-ITS)	CORRIGÉ
Tracking par ID fixe	Pseudonymes à courte durée de vie (rotation horaire)	MITIGÉ
Rejeu de messages V2X	Timestamp signé + fenêtre de validité courte (< 1 sec)	MITIGÉ
Wormhole / relais	Validation géographique (position dans le message signé)	MITIGÉ
Attaque Sybil	Limitation du nombre de pseudonymes actifs simultanés	ATTÉNUÉ
Certificats compromis	Liste de révocation (CRL) diffusée par les RSU	MITIGÉ

CORRECTIONS PARTIELLES

Capteurs & interfaces · partiellement corrigés.

Les attaques sur les capteurs physiques restent les plus difficiles à contrer. Des progrès significatifs ont été réalisés sur les interfaces externes depuis 2015.

ATTAQUE	SOLUTION DÉPLOYÉE	STATUT
Exploit TCU à distance (Jeep)	Isolation réseau APN, pare-feu, segmentation IP / CAN	CORRIGÉ
Pivot TCU → CAN	Gateway central avec filtrage strict des messages	MITIGÉ
Bluetooth / Wi-Fi vulnérable	Stack durcie, sandbox infotainment, pas d'accès CAN direct	MITIGÉ
GPS Spoofing	Multi-constellation (GPS + GLONASS + Galileo), fusion IMU	ATTÉNUÉ
Relay Attack (clé)	UWB (Ultra-Wide Band) avec mesure de distance	MITIGÉ
TPMS tracking / spoofing	Chiffrement des trames TPMS sur certains modèles haut de gamme	PARTIEL
LiDAR spoofing	Modulation pseudo-aléatoire des impulsions, fusion multi-capteurs	RECHERCHE
Adversarial caméra	Entraînement adversarial, fusion vision / radar / LiDAR	RECHERCHE

13

PARTIE 02 · VULNÉRABILITÉS & ATTAQUES

Normes & Conformité.

Du référentiel technique à l'obligation légale.

CADRE NORMATIF

Une norme par couche.

Chaque couche de l'architecture véhiculaire a son référentiel ; aucune norme unique ne couvre tout.

COUCHE	NORME (S)	OBJET
Gouvernance & cycle de vie	ISO/SAE 21434 · ISO 24089 · ISO 26262	Ingénierie cybersécurité · mise à jour logicielle · sécurité fonctionnelle (ASIL)
Bus intra-véhicule	ISO 11898 (CAN) · ISO 14229 (UDS) · AUTOSAR SecOC	Transport · diagnostic · authentification des trames
V2X / ITS	IEEE 1609.2 · ETSI TS 103 097 · ISO 21177	Certificats · en-tête de sécurité · session ITS sécurisée
Recharge / V2G	ISO 15118	« Plug & Charge » : TLS + certificats à la prise
Cloud & données	ISO 20078 (Extended Vehicle) · ISO/IEC 27001	Accès tiers aux données · SMSI organisationnel

Lecture · ISO/SAE 21434 chapeaute l'ensemble : l'ingénierie de cybersécurité sur tout le cycle de vie ; les autres normes en sont les briques techniques. ISO 26262 traite la sûreté de fonctionnement (ASIL), complémentaire de la cybersécurité, pas identique.

HOMOLOGATION & CONFORMITÉ

La conformité n'est plus optionnelle.

Depuis 2024, prouver sa cybersécurité conditionne l'accès au marché, ce n'est plus une bonne pratique, c'est la loi.

RÉGLEMENTATION CONTRAIGNANTE · UNECE WP.29 (ACCORD DE 1958)

UN R155 · CSMS · Système de management de la cybersécurité : identifier, évaluer et traiter les risques sur tout le cycle de vie.

UN R156 · SUMS · Système de gestion des mises à jour logicielles : intégrité et traçabilité des updates (dont OTA).

Périmètre · UE, Royaume-Uni, Japon, Corée du Sud · 60+ parties contractantes.

CALENDRIER

Juil. 2022 · obligatoire pour tout nouveau *type* de véhicule.

Juil. 2024 · obligatoire pour tout véhicule neuf produit (UE).

Janv. 2026 · Chine · GB 44495 / GB 44496 (nouveaux types ; tous types en 2028).

Sanction · pas de réception par type → interdiction de mise sur le marché.

Du standard à la loi · ISO/SAE 21434 et ISO 24089 restent volontaires, mais constituent le moyen reconnu de démontrer la conformité à UN R155/R156 lors de l'homologation.

MÉTHODE TARA · ISO/SAE 21434

Du risque à la contre-mesure.

L'analyse de risque (TARA) appliquée pas à pas à un scénario du simulateur, la méthode exigée par ISO/SAE 21434.

Scénario · injection d'une trame CAN usurpant l'ID du tableau de bord (vitesse / verrouillage des portes).

ÉTAPE TARA	ANALYSE DU SCÉNARIO
Bien & propriété	Trame CAN de commande · intégrité + authenticité
Scénario de menace	Usurpation (<i>spoofing</i>) : injection d'une trame au CAN ID légitime
Chemin d'attaque	Accès au bus (OBD-II / ECU compromis) → aucune authentification → trame acceptée
Impact (S/F/O/P)	Sécurité : grave · Opérationnel : majeur
Faisabilité	Élevée · IDs publics, outillage à bas coût, aucun MAC
Valeur de risque	Élevée (4/5)
Traitement · <i>réduire</i>	SecOC : MAC (AES-128-CMAC) + compteur de fraîcheur → « verify-or-drop »
Risque résiduel	Faible · trame forgée rejetée (MAC invalide ou rejeu détecté)

Boucle complète · menace identifiée (Partie 2) → risque évalué → traité par SecOC → risque résiduel documenté. C'est exactement le livrable attendu par ISO/SAE 21434 et exigé par UN R155.

DU RÉFÉRENTIEL AU BANC D'ESSAI

Le lab, à l'aune des normes.

Les contre-mesures du simulateur sécurisé ne sont pas ad hoc, chacune répond à une exigence normative précise.

MESURE DU LAB	RÉPOND À	EXIGENCE COUVERTE
SecOC · MAC AES-128-CMAC + compteur de fraîcheur, « verify-or-drop »	ISO/SAE 21434 (contre-mesure TARA) · AUTOSAR SecOC	Authenticité + intégrité + anti-rejeu des trames CAN
Durcissement UDS SecurityAccess	ISO 14229 · ISO/SAE 21434	Contrôle d'accès au diagnostic et au reflash
Journalisation & IDS CAN	ISO/SAE 21434 (détection & réponse)	Surveillance et réaction aux incidents
Mises à jour signées et intègres	UN R156 · ISO 24089	Chaîne de mise à jour logicielle de confiance

Continuité · une faille (Partie 2) → une analyse de risque (TARA) → une contre-mesure (SecOC / UDS) → une exigence normative (21434 / R155-R156). Le banc d'essai matérialise la conformité.

CONCLUSION

FIN DE LA PRÉSENTATION

À RETENIR

Le véhicule moderne n'est plus
un objet mécanique · c'est un
réseau distribué sur quatre roues.

TROIS AXES

Intra-véhicule · V2X · Capteurs & interfaces

TROIS DÉFENSES

Prévention · Détection · Atténuation

TROIS STANDARDS

UN R155 · UN R156 · ISO/SAE 21434